Data Security and Privacy Policy

Policy ID: SEC-003 **Version:** 3.0 **Effective Date:** 1 October 2026

Policy Owner: Information Security

1. Purpose

This policy defines minimum requirements for protecting company, customer, employee, and confidential information.

2. Data Classification

• Public: Information approved for unrestricted external distribution.

• Internal: Routine business information intended for authorized personnel.

• Confidential: Sensitive business, customer, financial, or operational information requiring controlled access.

• Restricted: Highly sensitive information requiring the strongest access controls, such as credentials, regulated personal data, or security secrets.

3. Access Control

• Access must be granted according to job responsibilities and the principle of least privilege.

• Employees must not share passwords, authentication tokens, or personal access credentials.

• Access should be removed promptly when an employee changes role or leaves the organization.

• Privileged access must use multi-factor authentication where supported.

4. Handling Sensitive Data

• Confidential and Restricted information must be stored only in approved systems.

• Sensitive files should not be sent to personal email or unauthorized cloud storage.

• Personal data should be collected and retained only for legitimate business purposes.

• Printed sensitive information must be securely stored or destroyed when no longer required.

5. Security Incident Reporting

Suspected phishing, malware, unauthorized access, accidental disclosure, lost devices, or other security incidents must be reported to the Information Security team immediately. Employees should not attempt to conceal an incident.

6. Retention and Disposal

Information must be retained according to applicable business and legal requirements. When retention ends, records should be securely deleted or destroyed using an approved method.

7. Frequently Asked Questions

• Can I upload confidential company data to an unapproved AI tool? No. Confidential or Restricted information must not be entered into unapproved external services.

• What should I do after clicking a suspicious link? Report it immediately to Information Security and follow the incident-response instructions.

• Who can access Restricted data? Only specifically authorized personnel with a legitimate business need.

Document status: Internal reference document for RAG testing. This synthetic policy is created for demonstration and does not represent the policy of a real organization.